

AgentsGate

ルール&ポリシー — 入門ガイド（日本語版）

日本語版 — 英語版は [agentsgate-rules-guide.pdf](#)

Version 1.2 ・ 2026-07-31 ・ for AgentsGate 0.1.3

AgentsGate ルール&ポリシー 入門ガイド

保護レベル

データベースの読み取り: 集計とテーブル名

機微に見えるテーブル名やカラム名 (users、passwords、tokens、credentials、billing など) を含む SELECT は 0.60 になり、strict レベルでは承認待ちになります。この挙動には引っかけやすい点が 2 つあります。

集計は除外されます。SELECT count(*) FROM users は数値を 1 つ返すだけでカラムの値を返さないため、他の読み取りと同じ 0.05 です。除外されるのは count() だけです。max(password) は最大のパスワードそのものを返し、group_concat(email) は全行を 1 つの文字列で返し、sum(balance) WHERE id = 42 は特定の 1 人の残高になります。

単数形・複数形の両方が対象です。user、users、public."User"、app_user、user_accounts はいずれも一致します。カラム名の user_id は一致しません — 単数形は FROM や JOIN の直後、つまりテーブルの位置でのみ認識されます。

スコアだけでは「何をすべきか」を決められません。DROP TABLE は 1.00、SELECT * FROM users は 0.60 ですが、この 2 つは程度ではなく種類が違います。SELECT を通すためにしきい値を上げると、DELETE FROM orders (0.90) まで通ってしまいます。そのため組み込みルールにはカテゴリが付いており、保護レベルがカテゴリごとの扱いを決めます。

agentsgate level — いま何が止まるのか、その理由を表示します

agentsgate level strict — 変更します。ダッシュボードのヘッダにも同じ切り替えがあり、そちらで変更すると実行中のプロキシに即座に反映されます。

minimal — 全消し系だけを止めます (DROP、TRUNCATE、WHERE 句のない DELETE)。使い捨てのプロジェクト向けです。

balanced — 既定。上記に加えて認証情報ファイル (.env、.pem) と外部データの削除を止めます。コードを書く、テストを走らせる、行を更新する — いずれも確認なしで通ります。

strict — 個人情報の読み出し、外部への送信、シェル実行、削除を承認対象に加えます。自分だけのものではないデータを扱う場合向けです。

balanced は利便性のための設定であって、データ保護の姿勢ではありません。シェルコマンドは実行され、users という名前のテーブルも読み取れます。ポリシールールはレベルの後に適用され、レベルより優先されます。

このガイドでは、AgentsGateのポリシールールのカスタマイズ方法を説明します。AIエージェントの操作を許可・ブロック・承認待ちにする仕組みを、プログラミング知識なしで設定できます。

1. ルールの仕組み

AIエージェントがツール呼び出し (ファイルの読み取り、メール送信、データベース問い合わせなど) を行うたびに、AgentsGateは2つのレイヤーのルールで評価します：

- **組み込みL1ルール** — 常時実行されるハードコードされた安全ルール。削除はできませんが、ミュートやスコア調整は可能です。
- **カスタムポリシールール** — あなたが作成するルール。L1の後で実行され、スコアを上書きしたりアクションを強制したりできます。

各ルールは次のどちらかを行います：

- **リスクスコアを設定する** (0.0 = 安全 → 1.0 = 危険) — すべての一致ルールの中で最も高いスコアが最終結果を決定します
- **アクションを強制する** — block (ブロック)、allow (許可)、require_approval (承認必須)。しきい値計算をバイパスします

💡 L1ルールを工場の警報システムと考えてください。カスタムルールは特定の人やチームに渡すアクセスバッジと上書きキーです。

2. ダッシュボードのRulesタブ

ダッシュボード (<http://localhost:4001>) を開き、Rulesタブをクリックします。3つのセクションが表示されます：

ポリシールール表

すべてのカスタムルールがHits（ヒット数）列付きで一覧表示されます。ヒット数が0（薄いテキスト）のルールは不要な可能性があります。

列	表示内容
Priority	評価順序 — 数値が低いほど先に評価
ID	ルールの一意の識別子
Description	あなたが設定した説明文
Tool	ルールが対象とするMCPツール
Method	ルールが対象とするメソッド
Action	block / allow / require_approval
Score	カスタムリスクスコアの上書き（設定時）
Hits	このルールが実際に発火した回数
Actions	編集・削除ボタン

組み込みL1ルールセクション

すべてのハードコードされたL1ルール（ID、デフォルトスコア、説明）を表示します。ダッシュボードから削除はできませんが、ポリシーファイルでミュートまたはスコア上書きが可能です。

プリセットテンプレート

JSONを書かずに一般的な保護ルールを作成できる6つのワンクリックボタン：

プリセット	作成されるルール
ファイル削除をブロック	filesystemツールでのdelete / remove / unlink / rmdir操作をブロック
承認必須：メール	GmailのSend / Reply / Forward操作に承認を要求
承認必須：Slack	Slackの公開チャンネルへのメッセージ送信に承認を要求
読み取り専用エージェント	指定エージェントのwrite / delete / create / update操作をブロック（追加後にagentIdを編集）
社内メールを信頼	社内ドメイン宛メール操作を自動許可
カレンダー削除をブロック	Google Calendarのdelete / remove / cancel操作をブロック

プリセットをクリックするとルールエディタが事前入力された状態で開きます。内容を確認して必要に応じて調整し、Saveをクリックします。

3. 操作行からのクイックルール作成

疑わしい操作を発見したとき、Overviewタブを離れずにそのままルールに変換できます。

使い方

- Overviewタブを開く
- 任意の行をクリックして詳細パネルを展開する
- 詳細パネル下部のQuick rule:バーまでスクロールする
- **Block ツール/メソッド** — この特定の組み合わせをブロックするルールを作成
 - **Require approval** — この操作を承認待ちにするルールを作成
 - **Trust agent agentId** — この特定エージェントを常に信頼するallowルールを作成
- 各ボタンはルールエディタを事前入力済みの状態で開きます — 調整してSaveをクリック

例：予期しないSlackメッセージをブロックする

- slack → send_messageという操作を発見 — エージェントがSlackメッセージを送信しているとは思っていなかった
- 操作行をクリックして詳細パネルを展開する
- Quick rule:バーの「Block slack/send_message」をクリック
- ルールエディタが ID: BLOCK_SLACK_SEND_MESSAGE、action: block、tool: slack、method: send_message で事前入力された状態で開く
- 必要に応じて説明を調整し、Saveをクリック
- ルールは即座に有効になります — 以降のslack/send_message呼び出しはブロックされます

💡 クイック作成したルールはparamsMatchでさらに絞り込めます。例えば「特定チャンネルへの送信だけをブロック」「特定宛先へのメールだけを承認必須にする」などの細かな制御が可能です。

4. ルールの手動作成と編集

RulesタブのNew Ruleをクリックしてルールエディタを開きます。policy.jsonを直接編集することもできます — ファイルの場所：

```
~/agentsgate/policy.json (macOS / Linux)
C:\Users\<名前>\.agentsgate\policy.json (Windows)
```

ルールの構造

```
{
  "id": "MY_RULE_ID",
  "description": "説明文",
  "match": {
    "tool": "slack",
    "method": "send_message"
  },
  "action": "block",
  "priority": 10
}
```

フィールド	必須?	説明
id	必須	一意の識別子。ログとHits表に表示されます。
description	任意	ダッシュボードに表示される自由記述のラベル。
match	必須	一致条件（AND論理）。セクション5を参照。

フィールド	必須?	説明
action	任意	block、allow、またはrequire_approval。しきい値をバイパス。
score	任意	リスクスコアの上書き（0.0～1.0）。actionが未設定の場合に使用。
priority	任意	評価順序。デフォルト: 100。低い数値ほど先に評価。
redact	任意	ログで[REDACTED]に置き換えるパラメータキーのリスト。
max	任意	このルールが貢献できるスコアの上限。

5. マッチ条件 — 正しい操作を対象にする

"match" 内のすべてのフィールドが一致した場合にルールが発火します（AND論理）。完全一致文字列または **/regex/flags** パターンを使用できます。

マッチフィールド	対象	例
tool	MCPツール名	"slack" または "/gmail outlook/"
method	ツールメソッド名	"send_message" または "/delete remove/i"
agentId	エージェント識別子	"my-agent" または "/^prod-.*/"
pathPattern	params.pathまたはfilePath	"/secrets/" または "/\.env\$/"
tags	操作タグ（全て一致必須）	["production", "sensitive"]
paramsMatch	操作パラメータ内の任意フィールド	{ "channel": "/^D[A-Z0-9]+/" }

5a. シンプルな完全一致

slackツールのsend_messageメソッドへのすべての呼び出しに一致：

```
"match": { "tool": "slack", "method": "send_message" }
```

5b. 正規表現での一致

どのツールでもdeleteまたはremoveメソッドに一致（大文字小文字を区別しない）：

```
"match": { "method": "/delete|remove/i" }
```

5c. エージェントIDでの一致

"prod-"で始まるIDのエージェントからのすべての操作に一致：

```
"match": { "agentId": "/^prod-/" }
```

5d. パラメータ値での一致（paramsMatch）

paramsMatch を使うと、操作のparamsオブジェクト内の特定フィールドを検査できます。SlackのDMとチャンネルメッセージの区別、社内メールと社外メールの区別などに使います。

SlackダイレクトメッセージのみマッチさせるRule（DMのチャンネルIDは"D"で始まる）：

```
"match": {
  "tool": "slack",
  "method": "send_message",
  "paramsMatch": { "channel": "/^D[A-Z0-9]+/" }
}
```

6. ルールの完全なサンプル集

サンプルA — Slackメッセージを全てブロック

目的：AIエージェントが承認なしにSlackメッセージを送信できないようにする。

```
{
  "id": "BLOCK_ALL_SLACK_SEND",
  "description": "エージェントのSlackメッセージ送信を全てブロック",
  "match": { "tool": "slack", "method": "/send|post|reply/i" },
  "action": "block",
  "priority": 5
}
```

サンプルB — SlackダイレクトメッセージのみApproval

目的：公開チャンネルへの投稿は自由に許可するが、ダイレクトメッセージは承認を要求する。

```
{
  "id": "APPROVE_SLACK_DM",
  "description": "SlackダイレクトメッセージにApprovalを要求",
  "match": {
    "tool": "slack",
    "method": "send_message",
    "paramsMatch": { "channel": "/^D[A-Z0-9]+/" }
  },
  "action": "require_approval",
  "priority": 5
}
```

サンプルC — 社外宛メールのブロック

目的：社外のアドレス宛にメールを送れないようにする。

```
{
  "id": "BLOCK_EXTERNAL_EMAIL",
  "description": "社外宛メール送信をブロック",
  "match": {
    "tool": "gmail",
    "method": "/send|reply|forward/i",
    "paramsMatch": {
      "to": "/^(?!.*@mycompany\\.com).*$/ "
    }
  },
  "action": "block",
  "priority": 5
}
```

サンプルD — 本番カレンダーのイベント削除をブロック

目的：特定のGoogle Calendarをイベント削除から保護する。

```
{
  "id": "BLOCK_PROD_CALENDAR_DELETE",
  "description": "本番カレンダーのイベント削除をブロック",
  "match": {
    "tool": "google-calendar",
    "method": "delete_event",
    "paramsMatch": { "calendarId": "production@mycompany.com" }
  },
  "action": "block",
  "priority": 5
}
```

サンプルE — 読み取り専用エージェントを信頼する

目的：レポート用エージェントに低リスクスコアを設定し、承認プロンプトが発生しないようにする。

```
{
  "id": "TRUST_READONLY_AGENT",
  "description": "レポートエージェントを常時許可",
  "match": { "agentId": "reporting-agent" },
}
```

```
{
  "score": 0.05,
  "priority": 1
}
```

サンプルF — 機密パスへの書き込みをリスク上昇

目的：/secrets/や.envを含むパスへの書き込みは、デフォルトのしきい値に関わらず承認を必要とする。

```
{
  "id": "ELEVATE_SECRETS_WRITE",
  "description": "機密パスへの書き込みを高リスクとして扱う",
  "match": {
    "tool": "filesystem",
    "method": "/write|create|overwrite/i",
    "pathPattern": "/secrets/|/\\.env"
  },
  "score": 0.90,
  "priority": 10
}
```

7. 組み込みL1ルール一覧

これらのルールは常時実行されます。ルールを抑制するには "mutedRules" にIDを追加します。スコアを変更するには "ruleOverrides" を使います。

ファイルシステム&システム

ルールID	トリガー条件	スコア
L1_DELETE_FILE	delete_file、unlink、rm	0.90
L1_SENSITIVE_PATH_WRITE	.env、.ssh/、.aws/、credentialsへの書き込み	0.90
L1_DROP_TABLE	データベースツールでのdrop、truncate	0.95
L1_DELETE_RECORD	非ファイルシステムツールでのdelete、remove	0.75
L1_EXECUTE_COMMAND	execute、exec、shell、spawn	0.80
L1_GIT_FORCE_PUSH	gitツールでのforce、reset、rebase	0.85
L1_OVERWRITE_FILE	ファイルシステムでのwrite_file、overwrite、create	0.65
L1_READ_ONLY	read_*、list_*、get_*、describe_*	0.05
L1_SENSITIVE_FILE_TYPE	鍵・証明書系ファイルへの書き込み (.pem、.key、.env、.crt 等)	0.75

Slack

ルールID	トリガー条件	スコア
L1_SLACK_SEND	slackツールでのsend_message、post_message、reply	0.70
L1_SLACK_DELETE	slackツールでのdelete_message、delete、remove	0.80
L1_SLACK_READ	slackツールでのlist_*、get_*、read_*、history	0.05

Gmail

ルールID	トリガー条件	スコア
L1_GMAIL_SEND	gmailツールでのsend、reply、forward	0.90
L1_GMAIL_DRAFT	gmailツールでのdraft、create、compose（送信以外）	0.30
L1_GMAIL_DELETE	gmailツールでのdelete、trash、remove	0.85
L1_GMAIL_READ	gmailツールでのlist_*、get_*、read_*、search_*	0.05

Google Calendar

ルールID	トリガー条件	スコア
L1_GCAL_CREATE	google-calendarツールでのcreate_event、insert、add	0.40
L1_GCAL_UPDATE	google-calendarツールでのupdate_event、patch、modify	0.50
L1_GCAL_DELETE	google-calendarツールでのdelete_event、remove	0.70
L1_GCAL_READ	google-calendarツールでのlist_*、get_*、search_*	0.05

データベース (SQLite / PostgreSQL / MySQL)

Rule ID	Triggered by	Score
L1_DB_DROP	DROP TABLE / DATABASE / INDEX — 復旧不能なデータ消失	1.00
L1_DB_TRUNCATE	TRUNCATE — 行単位の復旧なしにテーブルを空にする	0.95
L1_DB_BATCH_DESTROY	SQLパラメータにセミコロン — 複文インジェクションの疑い	0.95
L1_DB_DELETE_NO_WHERE	WHERE句のないDELETE — 全行削除	0.90
L1_DB_UPDATE_NO_WHERE	WHERE句のないUPDATE — 全行更新	0.85
L1_DB_DDL	CREATE / ALTER / PRAGMA — スキーマ構造の変更	0.70
L1_DB_RESTORE	スナップショット復元 — 現在のテーブル内容を置き換える	0.60
L1_DB_EXFIL	機微なテーブル名へのSELECT (users, passwords, tokens, secrets, billing 等)	0.60
L1_DB_EXECUTE	WHERE句のあるINSERT / UPDATE / DELETE	0.30
L1_DB_READ	SELECT・テーブル一覧・スキーマ参照 (読み取り専用)	0.05

8. リスクしきい値の調整

3つの介入ゾーンはポリシーファイルの2つのしきい値で制御されます：

```
{
  "thresholds": {
    "allowBelow": 0.30,
    "blockAtOrAbove": 0.70
  }
}
```

スコア範囲	デフォルトのアクション	調整方法
0.00 – 0.29	自動的に許可	より厳格にしたい場合はallowBelowを下げる
0.30 – 0.69	一時停止 — 承認を要求	中断を減らしたい場合はこの範囲を狭める
0.70 – 1.00	完全にブロック	早めにブロックしたい場合はblockAtOrAboveを下げる

💡 最初はデフォルト値のままにしてください。agentsgate start --dry-runでドライランモードを数日間実行すると、エージェントの実際のスコア分布を確認でき、そこから調整できます。

9. 組み込みルールのミュートとスコア上書き

ルールのミュート (誤検知の抑制)

```
{
  "mutedRules": ["L1_OVERWRITE_FILE"]
}
```


ルールのスコアを上書き

```
{
  "ruleOverrides": {
    "L1_DELETE_FILE": 0.50,
    "L1_SLACK_SEND": 0.30
  }
}
```

ルールは引き続き発火・記録されます。一組み込みのスコアの代わりにあなたのスコアが使われます。`agentsgate policy list` でアクティブなルールIDを確認できます。

10. よくある問題と対処法

問題	考えられる原因	対処法
ルールが全く発火しない (Hits = 0)	matchフィールドが間違っている	ダッシュボードRulesタブのRule Testerで実際の操作に対してテストする
承認プロンプトが多すぎる	しきい値が低すぎる、またはルールが広すぎる	allowBelowを上げるか、ルールのmatch条件を絞り込む
正当な操作がブロックされる	L1ルールが過剰反応している	priority 1でaction: allowのカスタムルールを追加するか、L1ルールをミュートする
ルールが想定外の操作に発火する	正規表現が広すぎる	正規表現を厳しくするか、matchフィールドを追加する
変更が反映されない	policy.jsonが保存されていない/ パスが違う	ダッシュボードRulesタブのヘッダーに表示されているパスを確認する